

SecureOrg Inc.

PCI DSS Compliance Framework

Acceptable Use Policy

Document Reference:	AUP-002
Version:	1.4
Effective Date:	April 14, 2026
Document Owner:	Chief Information Security Officer
Classification:	CONFIDENTIAL
Review Cycle:	Annual
Framework:	PCI DSS v4.0

This document contains confidential and proprietary information. Unauthorized disclosure is prohibited.

1. Purpose and Scope

1.1 Purpose

This Acceptable Use Policy (AUP) defines the acceptable and unacceptable use of SecureOrg Inc. information technology resources, with particular attention to protecting cardholder data environments in compliance with PCI DSS v4.0 requirements. It establishes clear boundaries for technology use to reduce security risk and ensure legal and regulatory compliance.

1.2 Scope

This Policy applies to all employees, contractors, consultants, vendors, partners, and any other individuals granted access to SecureOrg Inc. IT systems, networks, devices, and data. This includes corporate-owned equipment, BYOD (Bring Your Own Device) when connected to corporate networks, and third-party systems accessing company data.

1.3 PCI DSS Alignment

This Policy supports PCI DSS v4.0 Requirements 1, 2, 5, 7, 8, 9, and 12, specifically addressing

acceptable use of network resources, system components in the CDE, and cardholder data handling.

2. General Use Principles

2.1 Authorized Use

IT resources are provided for legitimate business purposes. Users are authorized to:

- Access systems, applications, and data required to perform assigned job functions
- Use company email and collaboration tools for business communications
- Access approved internet resources for job-related research and productivity
- Use approved software and tools as designated by IT and the Information Security team
- Process cardholder data only through approved, PCI DSS-compliant systems and processes

2.2 Personal Use

Limited personal use of company IT resources is permitted provided it does not:

- Interfere with job performance or business operations
- Consume excessive bandwidth or system resources
- Violate any provision of this Policy or applicable law
- Involve access to or processing of cardholder data on personal devices or non-approved systems

2.3 Monitoring and Privacy

Users have no expectation of privacy when using company IT resources. SecureOrg Inc. reserves the right to monitor, log, audit, and inspect all activity on company systems at any time without prior notice. This monitoring is conducted in compliance with applicable law and is necessary for PCI DSS compliance requirements including Requirements 10.2 and 10.3 regarding audit logging.

3. Prohibited Uses

3.1 Data Security Violations

The following actions are strictly prohibited and constitute serious violations of this Policy:

- Accessing, copying, storing, or transmitting cardholder data outside of approved, PCI DSS-compliant systems
- Storing full PAN, CVV/CVC, PIN, or track data on personal devices, USB drives, or unapproved cloud storage
- Sending cardholder data via email, instant messaging, or other non-encrypted, unapproved channels
- Photographing or screen-capturing displays showing unmasked PANs or other restricted data
- Attempting to access data, systems, or network segments beyond authorized permissions
- Sharing access credentials or allowing others to use your system accounts

3.2 Network and System Misuse

- Installing unauthorized software, including browser extensions, plugins, or utilities on CDE systems
- Connecting unauthorized devices to the corporate network or CDE segments
- Attempting to bypass, disable, or circumvent security controls including firewalls, IDS/IPS, or DLP systems
- Using company network resources for port scanning, network probing, or penetration testing without written authorization
- Configuring unauthorized wireless access points or creating network tunnels
- Using personal VPN services or proxy servers to bypass corporate security controls

3.3 Email and Internet Misuse

- Accessing, downloading, or distributing obscene, offensive, or illegal content
- Using company email for unauthorized mass marketing, spam, or chain letters
- Clicking on suspicious links or opening attachments from unknown senders
- Using company systems to participate in illegal online activities
- Disclosing confidential company information or CHD through social media

3.4 Physical and Environmental

- Removing hardware or storage media containing CHD from secured areas without authorization
- Allowing unauthorized individuals physical access to systems in the CDE
- Leaving CHD visible on screens in public or unsecured areas (clean screen policy)

- Printing CHD unless explicitly required for business purposes with appropriate controls

4. Cardholder Data Handling

4.1 Handling Requirements

All users who interact with cardholder data must adhere to the following requirements:

- Never store SAD (CVV, track data, PINs) after authorization completion under any circumstances
- Always use masked or tokenized PANs in test environments and communications
- Transmit CHD only through approved encrypted channels (TLS 1.2 minimum)
- Access CHD only from approved, hardened workstations within the designated CDE
- Log all access to CHD in accordance with the organization's logging standards
- Report any suspected unauthorized disclosure of CHD within 1 hour of discovery

4.2 Clean Desk and Screen Policy

To protect CHD from unauthorized visual access:

- Unattended workstations displaying CHD must be locked (screen lock activates within 15 minutes of inactivity in the CDE, 5 minutes for unattended sessions)
- Printed materials containing CHD must not be left unattended and must be shredded when no longer needed
- CHD must not be written on whiteboards, sticky notes, or other non-secure media
- Workstations in CDE areas must face away from public view or use privacy screens

5. Mobile Device and Remote Access

5.1 Mobile Device Policy

Use of mobile devices in connection with cardholder data is subject to the following controls:

- Only company-managed mobile devices with approved MDM software are permitted to access corporate systems
- Personal devices may not be used to access, store, or process CHD under any circumstances
- Mobile devices used in the CDE must have device encryption, remote wipe capability,

and approved security software enabled

- Camera use is prohibited in areas where CHD is visible

5.2 Remote Access

- Remote access to corporate systems requires MFA authentication without exception
- Remote access sessions accessing the CDE must use company-approved VPN with full tunnel routing
- Remote workers may not access the CDE from public Wi-Fi networks without company-issued VPN active
- Screen sharing of CHD during remote sessions is prohibited unless on approved, encrypted collaboration platforms for documented business purposes

6. Software and Application Use

6.1 Approved Software

Only software approved through the organization's software approval process may be installed on company systems. The Information Security team maintains and publishes the approved software list. Requests for new software must be submitted through the change management process and evaluated for:

- Security vulnerabilities and patch status
- License compliance
- Impact on PCI DSS compliance
- Data handling and privacy implications

6.2 Artificial Intelligence and Cloud Tools

Use of AI-powered tools, SaaS applications, or cloud storage services is subject to specific controls:

- CHD or SAD must never be entered into AI systems, chatbots, or any third-party cloud tool not explicitly approved for CHD handling
- Approval for new AI or cloud tools requires Information Security review and a data flow impact assessment
- Approved cloud services must have a signed Data Processing Agreement and evidence of PCI DSS compliance where applicable

7. Incident Reporting

7.1 Reporting Obligations

All users have an obligation to promptly report security events and Policy violations. Reports should be made immediately (within 1 hour for CDE-related events) through the following channels:

- Email: security@secureorg.com (monitored 24/7)
- Security Hotline: [Internal Extension] (24/7 for urgent issues)
- IT Helpdesk Ticketing System: Category 'Security Incident'
- Direct report to manager (who must then escalate to Information Security)

Failure to report a known security incident is itself a Policy violation and may result in disciplinary action.

8. Enforcement and Acknowledgement

8.1 Consequences of Violation

Violations of this Policy will result in appropriate disciplinary action, which may include revocation of system access, formal warnings, suspension, termination, and/or referral to law enforcement. The severity of consequences will be proportionate to the nature and impact of the violation.

8.2 User Acknowledgement

All users must acknowledge having read, understood, and agreed to comply with this Policy prior to being granted access to company IT systems. Acknowledgement is renewed annually as part of the security awareness training program. Digital acknowledgement records are maintained for audit purposes.

9. Revision History

1.0	Jan 15, 2024	Initial release	CISO Office
1.2	Jun 5, 2024	Added AI tools section; updated mobile device policy	Security Team

1.3	Jan 8, 2025	Updated remote access requirements; clean desk enhancements	CISO Office
1.4	Apr 14, 2026	Annual review; regulatory updates	CISO Office